GRC Guard AI

AI-Native Governance, Risk & Compliance for Banking

Explainable · Zero-Trust · Human-Approved Remediation

The Problem

- **Manual compliance** is slow, inconsistent, and rarely tied to live system evidence.
- **Black-box AI** cannot satisfy auditors or EU AI Act Art. 9/13 transparency requirements.
- **Multi-jurisdiction banks** juggle Basel III, GDPR, SOC 2, PCI DSS, ISO 27001, NIST CSF simultaneously.

Objective: AI-assisted compliance that is fast, explainable, and never trusted blindly — every AI output is either verified or requires human approval.

Inspector-Mechanic Architecture — 4 Layers

1. SENSE	Live connectors (Fineract, Wazuh, GCP, Workspace) + document RAG ingestion
2. REASON / INSPECT	Multi-agent Brain: Compliance Auditor, Risk Assessor, Policy Researcher, Jurisdiction Reconciler
3. ACT / MECHANIC	Proposes control/risk status changes — never applies them directly
4. LEARN	Auditor feedback (up/down votes) captured as DPO preference pairs for future tuning

Phase 1 — Fine-Tuning Without a GPU

- **GPU quota was denied** — Vertex AI's managed Supervised Fine-Tuning runs on Google's own fleet instead.
- **Base model:** gemini-2.5-flash — the same model already serving the Brain, so tuning is a drop-in swap.
- **Trained on:** a perspective-labeled Basel III/CBEST/GDPR/AML/SOC 2 instruction corpus.
- **In-app trigger:** Settings → AI Gateway → “Fine-tune on Vertex AI”, one click, no local infra.

~60%	~93%	40
TRAINING ACCURACY (start)	TRAINING ACCURACY (end)	EPOCHS

Phase 2 — Explainable AI, Honestly Labeled

- **Real perturbation LIME:** removes each candidate word and re-queries the live model to measure the actual confidenc
- **Verified, not simulated:** flips in the model's own decision are flagged and shown to the auditor.
- **Self-reported attributions** (the LLM explaining itself) are explicitly labeled as unverified — never confused with LIME.
- **SHAP / attention-based XAI:** disclosed as blocked — needs open model weights, unavailable on a hosted API.

Phase 3 — Zero-Trust Attestation

- **Every outbound AI call is gated:** compliance data is refused if attestation fails — enforced in code, not just displayed
- **Real workload identity:** a Google-signed OIDC token verified against Google's public keys — not a self-signed claim.
- **Policy checks:** TLS encryption, zero data retention, pinned model version, approved region.
- **Maps to:** EU AI Act Art. 9 (Risk Management) + Art. 13 (Transparency).

Phase 4 — Mechanic: AI Proposes, Human Decides

- **The only AI write-path in the app:** a Mechanic agent proposes control/risk status changes.
- **Nothing is ever auto-applied:** every proposal sits in a queue awaiting explicit Admin approval.
- **Full audit trail:** approval writes the same ControlStatusEvent used by connector-driven changes — fully traceable.
- **Verified live:** propose → approve → real status change → visible on Controls Monitor, tested end-to-end.

Phase 5 — Empirical Validation (Live, Not Simulated)

56.2%	1.00	0.22	0/3
RULE-BASELINE ACCURACY	PRECISION	RECALL	BRAIN RUN AGREEMENT

Every miss was a false negative — the rule engine never called a real compliant scenario a violation.

The Brain's 0/3 run-to-run consistency is reported honestly, not hidden — it motivates the XAI/attestation/Mechanic safeguards built around it.

Live System Evidence, Not Demo Data

- **Apache Fineract:** 3/3 core-banking posture checks passed (maker-checker, password policy, audit trail).
- **Wazuh EDR:** 3/3 endpoint posture checks passed (sensor coverage, agent freshness, manager health).
- **Google Workspace:** real findings surfaced — 2 admins without 2SV, 1 dormant account >90 days.
- **Google Cloud:** real findings surfaced — SSH/RDP open to 0.0.0.0/0 on 2 firewall rules.

Known Limitations — Disclosed, Not Hidden

- **SHAP / attention XAI:** blocked without open model weights + GPU access.
- **RAG embedding quota:** 429s under load, gracefully falls back to lexical search.
- **Brain run-to-run consistency:** measured at 0/3 in the Chapter 4 harvest — an open research finding.
- **GCE compute quota:** occasionally requires manual pod-freeing during rolling deploys.

Thank You

Questions?